

Audit Logging & Security Telemetry Spec

The evidence layer of Aegis: what every request records, how the trail is made tamper-evident, and which anomalies raise an alert.

DOCUMENT	OWNER	PHASE	CLASSIFICATION
AEGIS-SEC-AUD-004 v1.0 · 17 Aug 2026	Abdullah Zubair Cybersecurity Engineer	Phases 1–3 Sign-off in week 12	Internal / Confidential

1 Principle — hashes, not bodies

The audit trail must prove what happened without becoming a second copy of the sensitive data it protects. Aegis therefore records metadata, classification decisions, and content hashes — never prompt or completion bodies. An auditor can establish who asked what kind of question, which policy fired, and where the request went, and still learn nothing they were not entitled to see.

2 Audit event schema

```
{
  "event_id":      "uuid-v7",
  "ts":           "2026-08-17T09:41:22.104Z",
  "actor":        { "user_id": "...", "roles": ["finance"], "dept": "..."},
  "session_id":   "...",
  "route":        { "provider": "vendor-a", "model": "...", "region": "eu"},
  "prompt_sha256": "...", // hash only, never the text
  "dlp":          { "pack": "v1.0", "classes": ["C3"], "action": "tokenize",
                    "match_count": 2, "latency_ms": 31},
  "rag":          { "collections": ["finance"], "chunks": 6, "filter": "enforced"},
  "tokens":       { "in": 812, "out": 240, "cost_usd": 0.0141},
  "outcome":      "allowed", // allowed | blocked | redacted | error
  "prev_hash":    "...", // hash chain over the preceding event
  "sig":          "ed25519:..."
}
```

Emitted for **every** request, including blocked and errored ones. A missing event is itself a security finding, and gaps in the sequence are alerted on.

3 Integrity requirements

- Append-only sink, write-once storage, with no delete or update grant for any application role.
- Hash chain across consecutive events; a daily root hash is signed with the audit key and stored separately.
- Clock discipline through NTP, with skew above two seconds raising an alert, so ordering stays defensible.
- Verification job replays the chain nightly and reports the first divergence with its event ID.

4 Retention & access

STREAM	RETENTION	WHO CAN READ IT	CONTAINS SENSITIVE TEXT
Security audit events	13 months	Security, internal audit	No — hashes only
DLP decision log	13 months	Security	No — class and count only
Gateway access log	90 days	Security, platform on-call	No
Usage & cost telemetry	24 months	Analytics, Team Lead	No — aggregate counters

Access to any stream is itself audited. Export requires Team Lead approval and is recorded against the requesting identity.

5 Anomaly rules v1

SIGNAL	CONDITION	SEVERITY	RESPONSE
Secret-block burst	3 or more C1 blocks by one actor within 10 minutes	High	Page security, notify manager
Retrieval volume spike	Chunk retrieval above 5× the actor's 30-day baseline	Medium	Throttle, review session
Filter bypass attempt	Any RAG query lacking the enforced RBAC filter	High	Reject, page on-call
Off-hours access	Sensitive-collection reads outside working hours	Medium	Daily review queue
Audit gap	Chain divergence, or requests without a matching event	High	Freeze release, investigate

6 Security console panels

Built with the UX and analytics leads on the Phase 2 monitoring dashboards, so security views share one data model with usage reporting.

- ☐ DLP actions over time, split by class, with drill-down to the rule that fired
- ☐ Top blocked actors and departments, ranked, with 30-day trend
- ☐ False-positive review queue, feeding pattern-pack tuning
- ☐ Retrieval heat map by collection and sensitivity tier
- ☐ Engine health: p95 added latency, error rate, fail-closed events
- ☐ Audit chain status, with last verified root hash and timestamp

7 Phase 3 security sign-off pack

1. Penetration test report, with every high and critical finding closed or formally accepted.
2. DLP effectiveness report: recall, false-positive rate, and p95 latency against the targets in AEGIS-SEC-DLP-001.
3. Key management evidence: register, rotation drill record, break-glass log.
4. Vector store control matrix, all ten controls verified per cluster.
5. Audit integrity proof: 30 consecutive days of verified chain roots.

Definition of done for the security workstream: a reviewer can pick any production request at random and reconstruct, from the trail alone, who made it, what was detected, what the gateway did, and where the data went — without ever reading the prompt.

PREPARED BY Abdullah Zubair Cybersecurity Engineer Signature / date	REVIEWED BY Swaadesh U.S Data Analytics Signature / date	APPROVED BY Hrishikesh Reddy Team Lead Signature / date
---	--	---